# Proyecto Sprint 6 — Respuesta a Incidentes: Quantia Pay

**Analista: Jose Iván Arango Franco**

**Fecha: 06/10/2026**

*Escenario: Martes 03:14 AM. Alerta P1 — la cuenta de servicio del pipeline CI/CD de Quantia Pay (procesadora de pagos 24/7) se autenticó desde un host no habitual, enumeró Active Directory y abrió una conexión saliente a una IP externa desconocida. El volumen de datos saliendo de la red aumenta. Restricción clave: Quantia Pay no puede dejar de procesar pagos — la contención no puede ser "apagar todo". Misión: detener el incidente sin romper el negocio, asegurar que el atacante quedó afuera, y documentar qué falló.*

*Propósito: Dominar el ciclo completo de respuesta a incidentes — declarar con criterio, contener sin sobre-reaccionar, preservar evidencia en el orden correcto, erradicar la causa raíz, y comunicar de forma estructurada hacia el supervisor y el negocio.*

**El simulador (IR Console) te da la experiencia y los datos de tu sesión. Este informe es donde demuestras tu criterio: la clasificación, las recomendaciones y el análisis los escribes tú. Usa tu Session Log descargado como fuente de datos.**

| Criterios de finalización — marca con X cuando completes cada punto |
|---|
| X Completé el tutorial del simulador y operé las seis fases del incidente |
| X Decidí si declarar el incidente y dimensioné su alcance, impacto y confianza |
| X Contuve la exfiltración con el método y el alcance correctos, sin tirar producción abajo |
| X Capturé la evidencia volátil en el orden correcto |
| X Identifiqué la causa raíz y removí todos los mecanismos de persistencia |
| X Completé los 6 puntos de verificación con su evidencia |
| X Redacté el resumen ejecutivo (BLUF) respetando la estructura fija |
| X Completé la matriz de brechas y las 3 recomendaciones priorizadas |
| X Descargué mi Session Log y entregué la hoja de cálculo |

# Fase 1: Triage y Declaración del Incidente — Evalúa Cap. 1

*Esta fase evalúa el capítulo 1 (Declaración y dimensionamiento del incidente).*

*Cuidado con la actividad legítima mezclada con la maliciosa: confundir el trabajo normal del pipeline con el ataque es un error que se penaliza.*

## 1. Decisión de Declaración

*¿Es un incidente? Justifica con las tres condiciones.*

| Condición | ¿Se cumple? (Sí/No) | Evidencia / Justificación |
|---|---|---|
| **Amenaza real** | Sí | La cuenta svc_ci_deploy, que solo opera desde los build-runners, inició sesión en jump-02 (host administrativo, nunca usado por esta cuenta). Desde esa sesión hubo enumeración masiva de LDAP, PowerShell con -EncodedCommand vía WinRM, consulta de "Domain Admins" y una conexión saliente a 198.51.100.23, una IP fuera de la allowlist y sin historial. Son 7 eventos encadenados con secuencia de ataque. Hay un adversario usando la cuenta, no el pipeline. |
| **Activos afectados** | Sí | Confirmados: la cuenta svc_ci_deploy y el host jump-02 (10.20.9.140). Hay datos saliendo de la red en vivo (1.2 GB a las 03:11:48, 3.8 GB a las 03:15:30). jump-02 tiene acceso a prod-payments y vault. |
| **Requiere respuesta coordinada** | Sí | La exfiltración estaba activa y creciendo. Se necesitaba, en paralelo: aislar el host y bloquear el destino (Redes), rotar el token (Identidad), parchar el pipeline (DevOps/CI-CD), preservar evidencia y reconstruir jump-02 (SOC e Infraestructura), y evaluar si hay datos de tarjetas en juego (Legal/Cumplimiento). Ningún equipo lo resuelve solo, y la decisión de contener sin tirar los pagos requiere al SOC Manager. |
| **Decisión final:** | *DECLARAR INCIDENTE* | |

## 2. Punto de Quiebre

*¿En qué evento empieza realmente el ataque, y por qué?*

El ataque empieza a las 03:02:15, en el login OK de svc_ci_deploy desde jump-02. Es el primer evento donde la cuenta se aparta de su comportamiento histórico: nunca había iniciado sesión en jump-02, y su patrón solo incluye los build-runners. Los eventos anteriores (02:47:03 login desde build-runner-03 y 02:51:22 pipeline #4471 deploy a prod con commit aprobado por una persona) son actividad legítima del pipeline, y todo lo posterior (LDAP, PowerShell codificado, net group, conexión externa, DATA_OUT) se explica a partir de ese acceso.

## 3. Alcance, Impacto y Confianza

| Dimensión | Confirmado | Potencial | Nivel de confianza |
|---|---|---|---|
| **Activos comprometidos** | Cuenta svc_ci_deploy y host jump-02 (10.20.9.140) | prod-payments y vault (alcanzables desde jump-02); otras cuentas privilegiadas, por la consulta a Domain Admins | *Alta* |
| **Datos comprometidos** | 3.8 GB enviados a 198.51.100.23 al momento del triage (03:15:30; el total final antes de contener fue 6.9 GB); listado de usuarios y grupos de Active Directory enumerado. | Hasta ~47 GB si no se contiene; el contenido de lo exfiltrado no está verificado y podría incluir datos de tarjetas. Además podría continuar la expansión hacia activos aún más críticos | *Media* |

## Fase 2: Contención — Evalúa Cap. 2

*Esta fase evalúa el capítulo 2 (Contención y preservación de evidencia).*

*Contener es frenar el sangrado ahora, no resolver todo. Reiniciar destruye la RAM; aislar de más tira producción abajo; una regla demasiado amplia corta el acceso legítimo.*

| Elemento | Tu respuesta |
|---|---|
| 1. Método de aislamiento elegido<br>¿Cuál elegiste y por qué? Incluye el trade-off respecto a la evidencia volátil. | Aislar por EDR (network containment). Corta el tráfico de red de jump-02 pero deja el host vivo y la RAM preservada, así que no se pierde evidencia volátil. Descarté reiniciar el host porque destruye la memoria de forma irreversible, y apagar la subnet entera porque habría tirado el procesamiento de pagos. El trade-off es que el host sigue encendido y comprometido, por lo que hay que capturar la evidencia volátil rápido (sus TTL corren) y no dejarlo así más tiempo del necesario. |
| 2. Regla de firewall aplicada<br>¿Qué regla escribiste y por qué ese alcance — no uno más amplio? | fw add-rule deny out src 10.20.9.140 dst 198.51.100.23/32 port 443. Bloquea solo el tráfico saliente de jump-02 hacia un único host del atacante por el puerto de la exfiltración. Una regla más amplia (toda la subnet o toda la salida) cortaría accesos legítimos a producción. |
| 3. Consecuencias de tus decisiones<br>¿Qué efecto tuvo cada acción? Incluye errores si los hubo. | El aislamiento por EDR cortó la red de jump-02 y dejó la RAM intacta. La regla /32 detuvo la exfiltración en 6.9 GB, contra un estimado de 47 GB si no se contenía, y las rutas a producción siguieron intactas (lo confirma el Session Log): sin impacto en los pagos. Capturé la evidencia volátil después del aislamiento EDR, que mantiene viva la RAM, y las 5 capturas salieron OK. No hubo reinicio ni pérdida de evidencia. No cometí errores de método ni de alcance; el costo fue el tiempo: salieron 6.9 GB antes de contener. |

### 4. Secuencia de Preservación de Evidencia

*Orden en que capturaste lo volátil antes de contener: de lo más efímero a lo más persistente.*

| Orden | Tipo de evidencia capturada | Por qué en este momento |
|---|---|---|
| **1** | Conexiones de red activas (netstat) | Es lo más efímero (TTL de 40 s) y muestra la conexión del atacante y sus procesos. |
| **2** | Caché ARP / tablas | TTL de 60 s; registra con qué hosts habló jump-02 en la red local. |
| **3** | RAM / procesos en memoria (ram-capture) | TTL de 90 s; contiene procesos y comandos en ejecución (ej. el PowerShell codificado) que no quedan en disco. |
| **4** | Imagen de disco (disk-image) | Es persistente, pero se captura antes de limpiar para conservar los artefactos de persistencia. |
| **5** | Exportación de logs (export-logs) | Es lo más persistente; se exporta último porque puede esperar sin perderse. |

# Fase 3: Erradicación y Verificación — Evalúa Cap. 3

*Esta fase evalúa el capítulo 3 (Erradicación, verificación y recuperación).*

*Declarar "está limpio" sin evidencia es el error más caro de toda la respuesta. Cada verificación necesita un hecho que la respalde, no un "me parece que sí".*

## 1. Causa Raíz

*Cómo entró el atacante (la causa, no el síntoma).*

El token de la cuenta de servicio svc_ci_deploy quedó expuesto en un build log público. El pipeline de CI/CD escribía secretos en sus logs sin enmascararlos, así que cualquiera con acceso al log pudo tomar la credencial y usarla como si fuera el pipeline. Todo lo demás (login en jump-02, enumeración, exfiltración) es consecuencia de esa credencial expuesta.

## 2. Mecanismos de Persistencia

*Todos los que encontraste y qué hiciste con cada uno. Dejar uno solo significa que el atacante regresa.*

| # | Mecanismo de persistencia encontrado | Acción tomada |
|---|---|---|
| **1** | Tarea programada maliciosa WindowsUpdateCheck: ejecuta PowerShell con -enc (comando codificado) cada 30 min. Se disfraza de actualización de Windows. | Eliminada con remove-persistence. En mi primer intento de erradicación esta tarea reactivó al atacante (re-infección). Reintenté la fase, removí las 2 persistencias maliciosas y no hubo re-infección. Lección: una sola persistencia olvidada basta para que el atacante regrese. |
| **2** | Clave de registro Run maliciosa OneDriveSync: apunta a C:\Users\Public\svc.exe, un ejecutable en una carpeta pública que se disfraza de OneDrive. | Eliminada con remove-persistence. |
| **3** | Tarea programada BackupAgent (backup-agent.exe): clasificada como legítima. | Descartado como legítimo; no se tocó (agente de respaldo del negocio). |
| **4** | Servicio QuantiaPayPOS (pos-service.exe): clasificado como legítimo. | Descartado como legítimo; no se tocó (servicio legítimo del negocio; removerlo habría causado una caída). El Session Log confirma 0 servicios legítimos tocados. |

## 3. Los 6 Puntos de Verificación

*Cada uno con la evidencia concreta que prueba que está resuelto.*

| Punto de verificación | Estado (Resuelto/Pendiente) | Evidencia concreta |
|---|---|---|
| **Cuenta svc_ci_deploy: credencial vieja inválida** | *Resuelto* | Token rotado (✓ en Erradicación). verify account-status → OK: la credencial anterior ya no es válida. |

| Fase 3: Erradicación y Verificación — Evalúa Cap. 3 | | |
|---|---|---|
| **jump-02 sin mecanismos de persistencia activos** | *Resuelto* | No quedan persistencias conocidas: las 2 maliciosas (WindowsUpdateCheck y OneDriveSync) fueron eliminadas (verify persistence-clear → OK); las 2 legítimas (BackupAgent y QuantiaPayPOS) siguen en el host. La verificación cubre solo lo enumerado, por eso la decisión de recuperación es reconstruir el host. |
| **Acceso del atacante cortado** | *Resuelto* | El host está aislado por EDR, la regla deny out hacia 198.51.100.23/32 (puerto 443) está aplicada y el monitor de exfiltración muestra STATUS: BLOCKED; además, el token usado para entrar fue rotado. verify attacker-access → OK. |
| **Causa raíz corregida (pipeline expone secretos)** | *Resuelto* | Pipeline parchado (✓ en Erradicación): ya no escribe secretos en los logs. verify root-cause-fixed → OK. |
| **Sin hosts adicionales comprometidos** | *Resuelto* | Los eventos del ataque registrados tienen a jump-02 como origen (login, LDAP, PowerShell, conexión externa, DATA_OUT), no hay actividad de svc_ci_deploy en otro host después de las 03:02:15, y el mapa marca sanos a build-runner-03, prod-payments y vault. verify lateral-movement → OK. Límite: es lo visible en el simulador, sin búsqueda en otros hosts; por eso el monitoreo (punto 6) sigue activo. |
| **Monitoreo activo sobre la cuenta/IP** | *Resuelto* | Regla de monitoreo creada (✓ en Erradicación) sobre svc_ci_deploy y la IP 198.51.100.23. verify monitoring-active → OK. |

## 4. Decisión de Recuperación

| Elemento | Tu respuesta |
|---|---|
| Reconstruir o limpiar<br>¿Cuál elegiste? | Reconstruir jump-02. |
| Justificación<br>¿Por qué esa opción y no la otra? | jump-02 tuvo ejecución remota con PowerShell codificado y 2 persistencias; eliminé las que encontré, pero la búsqueda solo cubre lo enumerado y no puedo garantizar que no haya otra. Es un host de administración con acceso a prod-payments y vault, así que un residuo ahí tiene alto valor para el atacante. Reconstruirlo es un costo operativo acotado (es un bastión, no el servicio que procesa pagos, que sigue operando) y la evidencia ya estaba preservada. |
| RTO aceptable<br>Tiempo de recuperación (Recovery Time Objective) aceptable. | 2 horas: durante ese tiempo se pierde la vía de acceso administrativa por jump-02, sin impacto en el procesamiento de pagos. Los 20 min de limpiar en caliente no compensan el riesgo de dejar un residuo en un host con acceso a producción. |

## Fase 4: Comunicación Ejecutiva (BLUF) — Evalúa Cap. 4

*Esta fase evalúa el capítulo 4 (Comunicación bajo incertidumbre).*

*Roberto necesita un resumen que pueda leer en 90 segundos y reenviar a dirección. Escribe pensando en alguien que no es técnico y que tiene poco tiempo. Evita los dos extremos: el informe vago lleno de "podría/tal vez", y el alarmista sin evidencia.*

### 1. CONCLUSIÓN

*La línea de fondo, lo primero que se lee.*

Un atacante usó una credencial robada del sistema de despliegue y sacó 6.9 GB de datos de Quantia Pay antes de que lo bloqueáramos. El acceso está cortado, la causa corregida y los pagos no se vieron afectados; falta confirmar qué datos contenían esos 6.9 GB.

### 2. QUÉ PASÓ

*El incidente en dos o tres líneas.*

A las 03:02 alguien usó la credencial de la cuenta del pipeline de despliegue, que había quedado expuesta en un registro público, para entrar a un servidor de administración. Desde ahí reconoció la red, buscó las cuentas con más privilegios y empezó a enviar datos a una dirección externa. Nuestro sistema de alertas lo detectó a las 03:14 y se inició la respuesta de inmediato.

### 3. IMPACTO CONFIRMADO

*Qué se vio afectado de verdad (sin sobre-declarar).*

6.9 GB de datos enviados a una IP externa antes de que se bloqueara la salida.
Una cuenta de servicio y un servidor de administración (jump-02) comprometidos.
Sin impacto en el procesamiento de pagos, que siguió operando con normalidad.
No se detectó actividad del atacante en otros equipos.

Lo que no está confirmado: el contenido de los 6.9 GB (podría incluir datos de tarjetas) y si el atacante llegó a usar otras cuentas privilegiadas.

### 4. ESTADO ACTUAL

*Dónde está el incidente ahora.*

Contenido. La salida de datos está bloqueada, la credencial robada fue rotada, el pipeline corregido y se eliminaron los 2 mecanismos que el atacante dejó. Las 6 verificaciones de cierre pasaron. Pendiente: reconstruir jump-02 (aprox. 2 h). La evidencia (memoria, disco, logs, red) está preservada.

| Fase 4: Comunicación Ejecutiva (BLUF) — Evalúa Cap. 4 |
|---|
| **5. PRÓXIMOS PASOS** |
| *Una acción inmediata y una de cierre.* |
| Inmediata: analizar la evidencia preservada para confirmar qué datos salieron (en especial si incluyen datos de tarjetas) y decidir con Legal/Cumplimiento si corresponde notificar. Responsable: SOC. Plazo: 24 horas.<br>De cierre: reconstruir jump-02 desde una imagen limpia (aprox. 2 h, sin impacto en pagos) y cerrar formalmente el incidente cuando pase la verificación. |

# Fase 5: Cierre y Prevención — Evalúa Cap. 5

*Esta fase evalúa el capítulo 5 (Análisis post-incidente y recomendaciones).*

*El análisis de brechas no es buscar a quién echarle la culpa: es encontrar los huecos del sistema. Una recomendación sin responsable ni fecha es un deseo, no un plan.*

## 1. Matriz de Brechas de Control

*Por cada evento del ataque: qué control faltó o falló, y de qué tipo es.*

| Evento del ataque | Control que faltó / falló | Tipo de control |
|---|---|---|
| Token expuesto en build log público (causa raíz) | Sin escaneo ni enmascarado de secretos en el CI/CD; token estático, sin evidencia de expiración o rotación | *Preventivo* |
| 03:02:15 · Login desde jump-02 | Sin restricción de desde qué hosts puede iniciar sesión la cuenta (solo build-runners) | *Preventivo* |
| 03:02:15 · Login desde jump-02 | Sin alerta por login desde un host fuera del patrón histórico de la cuenta | *Detección* |
| 03:03:41 · LDAP masivo y 03:06:33 · net group "Domain Admins" | Escalada detectada tarde: sin alerta por enumeración de AD; la P1 llegó a las 03:14 | *Detección* |
| 03:05:08 · PowerShell -EncodedCommand vía WinRM | Sin alerta por PowerShell codificado ejecutado remotamente | *Detección* |
| Persistencia en jump-02 (WindowsUpdateCheck y OneDriveSync; hora no registrada) | Sin alerta de baseline por tareas programadas o claves Run nuevas | *Detección* |
| 03:09:17 · Conexión saliente a 198.51.100.23 | Sin filtrado de salida con allowlist | *Preventivo* |
| 03:11:48 · DATA_OUT | Sin alerta por volumen o destino nuevo; la P1 llegó a las 03:14, casi 12 min después del login | *Detección* |
| 03:15:30 · Exfiltración en curso | Contención dependió de pasos manuales: sin aislamiento automático ni revocación automática del token | *Correctivo* |

## 2. Recomendaciones Priorizadas

## Fase 5: Cierre y Prevención — Evalúa Cap. 5

*Tres recomendaciones accionables, ordenadas por impacto y esfuerzo.*

| # | Qué cambia | Responsable | Para cuándo | Cómo se verifica | Qué previene | Impacto / Esfuerzo |
|---|---|---|---|---|---|---|
| **1** | Activar escaneo de secretos en el repositorio y el CI/CD, enmascarar secretos en los build logs y reemplazar el token estático por credenciales de corta duración gestionadas desde el vault. | Líder de plataforma CI/CD / DevSecOps | 2026-10-19 | Prueba controlada: un commit con un secreto falso es bloqueado y un secreto de prueba aparece enmascarado en el log. Revisión de que ninguna cuenta de servicio use credenciales sin expiración. | Que una credencial se filtre por los logs y se use desde fuera (causa raíz de este incidente). | Alto / Bajo-Medio |
| **2** | Restringir svc_ci_deploy para que solo pueda iniciar sesión desde los build-runners y reducir sus permisos en Active Directory al mínimo que necesita el pipeline. | Equipo de Identidad / Administración de AD | 2026-11-02 | Prueba controlada: un intento de login desde jump-02 es rechazado y queda en los logs. Revisión de los permisos de la cuenta contra la lista aprobada. | Que una credencial robada sirva para entrar a hosts de administración y enumerar el directorio. | Alto / Bajo |
| **3** | Aplicar filtrado de salida con allowlist en la subred de administración y crear reglas en el SIEM para logins fuera de baseline, PowerShell codificado remoto y volumen anómalo de datos salientes. | Equipo de Redes / SOC (Roberto Silva) | 2026-11-30 | Prueba controlada: una conexión a una IP no aprobada es bloqueada y genera alerta en el SIEM en menos de 5 minutos. | Que una exfiltración avance varios GB antes de ser detectada y detenida. | Alto / Medio-Alto |

SESSION LOG · IR-2026-0847 · Quantia Pay · anon · —
Generado: 2026-10-06T06:11:38.198Z

---

SCORE GLOBAL: 98/100
Fase 1 Triage 100/100 Breakpoint correcto.
Fase 2 Contención 93/100 EDR + regla /32 perfecta.
Fase 3 Evidencia 100/100 Capturas: 5/5
Fase 4 Erradicación 95/100 2/2 maliciosos removidos · 0 legítimos tocados
Fase 5 Verificación 100/100 6/6 checks OK

---

DECISIÓN DE DECLARACIÓN: Incidente declarado
PUNTO DE QUIEBRE MARCADO: e3 (correcto · 03:02)
CONTENCIÓN APLICADA: EDR · firewall perfect
EXFILTRACIÓN ANTES DE CONTENER: 6.9 GB
EVIDENCIA CAPTURADA: netstat ✓ · arp ✓ · ram ✓ · disk ✓ · logs ✓
CAUSA RAÍZ MARCADA: token
PERSISTENCIA: WindowsUpdateCheck removida ✓, OneDriveSync removida ✓
DAÑO COLATERAL: 0 servicios legítimos tocados

TOKEN ROTADO: sí · PIPELINE PARCHADO: sí · MONITOREO: sí
RE-INFECCIÓN: no
VERIFICACIÓN: account-status=OK · persistence-clear=OK · attacker-access=OK · root-cause-fixed=OK · lateral-movement=
RECUPERACIÓN: rebuild · Reconstruir: jump-02 tuvo ejecución remota con PowerShell codificado y 2 persistencias; no pue

---

TIMELINE DE ACCIONES:
[9:49:19 PM] F0 INFO — Tutorial saltado
[9:49:37 PM] F1 OK — Incidente declarado · breakpoint=e3 · score=100/100
[9:49:47 PM] F2 OK — Aislamiento EDR · jump-02 ISOLATED · RAM preservada
[9:50:38 PM] F2 OK — Regla quirúrgica /32 aplicada · exfil bloqueada · rutas a prod intactas
[9:50:40 PM] F2 INFO — Fase contención cerrada · score=93/100 · exfil=6.9 GB
[9:52:50 PM] F3 INFO — Evidencia: 5 fuentes capturadas · score=100
[9:53:35 PM] F4 ERR — RE-INFECCIÓN: WindowsUpdateCheck reactivó al atacante
[10:07:31 PM] F4 INFO — Erradicación · score=75
[10:21:42 PM] F4 INFO — Erradicación · score=95
[10:27:01 PM] F5 OK — Verificación completa · 6/6 OK

---

DATOS PARA TU INFORME EN EXCEL:
Eventos clave del ataque (para la matriz de brechas):
- 03:02:15 [AUTH] login OK svc_ci_deploy desde jump-02
- 03:03:41 [AD] consulta LDAP masiva (enumeración)
- 03:05:08 [ENDPOINT] powershell -EncodedCommand (WinRM)
- 03:06:33 [ENDPOINT] net group "Domain Admins" /domain
- 03:09:17 [RED] conexión saliente a 198.51.100.23:443
- 03:11:48 [RED] DATA_OUT 1.2 GB a 198.51.100.23
- 03:15:30 [RED] DATA_OUT 3.8 GB acumulado · EN CURSO

Controles que fallaron (clasifica tú el tipo en el Excel):
- Token en log público (control de gestión de secretos)
- Login desde host no habitual sin alerta
- Escalada AD detectada tarde
- Persistencia creada sin alerta de baseline
- Exfil saliente sin DLP/egress filtering